



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-20253 Splunk Enterprise Missing Authentication File Operation Risk

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-22
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-20253 Splunk Enterprise Missing Authentication File Operation Risk - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-22 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-20253 Splunk Enterprise Missing Authentication File Operation Risk

1. Executive Summary

CVE-2026-20253 is the second vulnerability priority because Splunk commonly holds high-value telemetry, credentials, tokens, saved searches, and investigation context. CISA added the issue to KEV on 2026-06-18 after evidence of exploitation; the described impact is unauthenticated creation or truncation of arbitrary files via a PostgreSQL sidecar service endpoint.

This report was produced from sources available during the 2026-06-22 UTC daily automation window. It prioritizes defender action over exploit reproduction. No exploit code was run and no private victim data was used.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-20253
Product / Component	Splunk Enterprise with PostgreSQL sidecar service endpoint
Weakness	Missing authentication for critical function allowing unauthenticated arbitrary file creation or truncation through a sidecar endpoint
Severity	High/Critical operational priority (CISA KEV; vendor advisory SVD-2026-0603)
Affected Versions	Affected Splunk Enterprise deployments per Splunk advisory SVD-2026-0603
Fixed Versions / Mitigation	Apply Splunk fixed versions/mitigations in SVD-2026-0603; restrict sidecar reachability
Disclosure / KEV Date	2026-06-18 CISA KEV addition
Exploitation Status	Known exploited according to CISA KEV; ransomware association not publicly confirmed in KEV

3. Source Review & Confidence

Source	Contribution	Confidence
CISA KEV	Active exploitation and federal remediation due date	High
Splunk advisory	Vendor remediation and product scope	High
NVD	CVE enrichment and reference tracking	High
CISA BOD 26-04	Risk-based prioritization context	High

Confidence is High for prioritization because CISA KEV and vendor or primary research sources corroborate exploitation or remediation urgency. Exact affected-version scoping should still be validated against the vendor advisory before emergency change approval.

4. Vulnerability Details

The vulnerability is not merely a Splunk availability bug. Arbitrary file creation or truncation against a telemetry platform can destroy evidence, alter application behavior, affect scripted inputs, or create a staging point for follow-on abuse depending on file path and service permissions. Internet-exposed management or sidecar reachability sharply increases priority.

5. Attack Scenarios

Scenario	Defender Concern	Priority
Internet-facing affected instance	Remote exploitation may provide initial access or destructive application impact.	Critical
Internally reachable high-value application	A compromised partner, VPN user, or phishing foothold can pivot to the affected service.	High
Patched system with exposed historical logs	Still requires compromise assessment for activity before the fix.	High

6. Threat Landscape & Exploitation Status

CISA lists CVE-2026-20253 in the Known Exploited Vulnerabilities catalog. That listing means defenders should prioritize remediation and evidence review even if their scanner severity or asset owner categorization is lower. Public reporting available during this run supports urgent triage; details that are not explicitly published are intentionally not inferred as fact.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters	Immediate Check
Publicly reachable management/application endpoint	Highest likelihood of exploitation attempts and automated scanning.	Confirm internet exposure, reverse proxy logs, and WAF telemetry.
Privileged identity or telemetry platform	Compromise can amplify downstream access or reduce investigation visibility.	Review service account scope and administrative changes.
No known exposure but installed	Vulnerability management still matters because lateral movement can reach internal services.	Patch and preserve logs for lookback.

8. Mitigation and Workarounds

Priority	Owner	Action
Critical	Application / platform owner	Apply vendor patches or emergency mitigations and document exact fixed version.
Critical	Network / edge team	Restrict vulnerable endpoints to trusted admin networks until patched and verified.
High	SOC / IR	Run a 30-day lookback for exploitation signals and preserve relevant logs.
High	Identity team	Rotate credentials/secrets reachable from the affected application if compromise is suspected.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
HTTP or sidecar service requests to unexpected Splunk endpoints from non-admin sources	Application, EDR, web, or file telemetry	Confirm exploitation or follow-on activity.
Unexpected file creation/truncation under Splunk application, var, or sidecar paths	Application, EDR, web, or file telemetry	Confirm exploitation or follow-on activity.
Splunk service restarts, app errors, or missing telemetry immediately after suspicious requests	Application, EDR, web, or file telemetry	Confirm exploitation or follow-on activity.

9.2. Sigma / Detection Rule

<pre> title: CVE-2026-20253 Suspicious Exploitation Follow-On Activity status: experimental description: Detects suspicious process or file activity around systems that should be reviewed after CVE-2026-20253 exploitation attempts. Tune paths and process names to the affected product. logsource: category: process_creation detection: selection_host_context: Image contains: - sh - bash - cmd.exe - powershell.exe - python - curl - wget selection_parent_context: ParentImage contains: - peoplesoft - splunk - java - postgres condition: selection_host_context and selection_parent_context fields: - Image - ParentImage - CommandLine - User - Computer falsepositives: - Administrative maintenance scripts; validate change ticket and source host. level: high </pre>
--

9.3. Hunt Query

<pre> DeviceProcessEvents where Timestamp > ago(30d) where InitiatingProcessFileName has_any ("splunk", "postgres", "java", "psadmin", "tuxedo") where FileName in~ ("cmd.exe", "powershell.exe", "bash", "sh", "python", "curl", "wget", "certutil.exe") project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName </pre>

10. Threat Hunting

10.1. Hunt Hypothesis

An attacker exploited an exposed application, then produced abnormal child process, file modification, or outbound network activity before or after public disclosure.

10.2. Hunt Query

```
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any ("PeopleSoft", "peoplesoft", "splunk", "Splunk")
| where ActionType in ("FileCreated", "FileModified", "FileDeleted")
| summarize event_count=count(), first_seen=min(Timestamp), last_seen=max(Timestamp) by DeviceName,
FolderPath, FileName, InitiatingProcessFileName, InitiatingProcessCommandLine
| where event_count > 3 or InitiatingProcessFileName !in~ ("splunkd.exe", "java.exe")
```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Remote exploitation of Splunk service surface
T1565.001	Stored Data Manipulation	Creation/truncation of arbitrary files can corrupt stored application data
T1070	Indicator Removal	Telemetry tampering is a defender-relevant consequence

12. Validation / Lab Testing

No exploit reproduction was performed in this automated daily run. Validation completed: source correlation against CISA/vendor/primary reporting, report rendering, PDF text extraction, and embedded detection-query survival checks.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Vulnerability management	Confirm whether CVE-2026-20253 is present and reachable in production, staging, or vendor-managed environments.
Critical	Platform owner	Patch or apply vendor mitigation; if patching is delayed, isolate affected endpoints.
High	SOC	Execute the included hunts and preserve evidence for any positive hits.
High	GRC / communications	Track exception owners and deadlines because this issue is in CISA KEV.

14. References

- [CISA KEV] https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- [Splunk advisory] <https://advisory.splunk.com/advisories/SVD-2026-0603>
- [NVD] <https://nvd.nist.gov/vuln/detail/CVE-2026-20253>
- [CISA BOD 26-04] <https://www.cisa.gov/news-events/directives/bod-26-04-prioritizing-security-updates-based-risk>